

Risk Identification and Assessment

IS 2204 - Information Systems Security

Dilanga Harshani

Content adapted from
Prof. Kasun De Zoysa & Mr. Kenneth Thilakarathna

University of Colombo School of Computing

August 3, 2026

Where You Are

- Introduction to Information Security and CIA Triad
- Symmetric and Asymmetric Cryptography
- Email and Document Security
- Transport Layer Security
- Payment Security and Blockchain
- Network Security Protocols
- Malicious Code and Defences
- Authentication Protocols
- **Risk Identification and Assessment**

Today's Roadmap

- **Understanding Risk** : What risk actually means, and why it must be managed
- **The Risk Management Process** : Identifying assets, risks, and their feasibility
- **Threat Modeling** : Systematic methodologies for finding what could go wrong
- **Vulnerability Assessment** : Finding what is actually weak right now

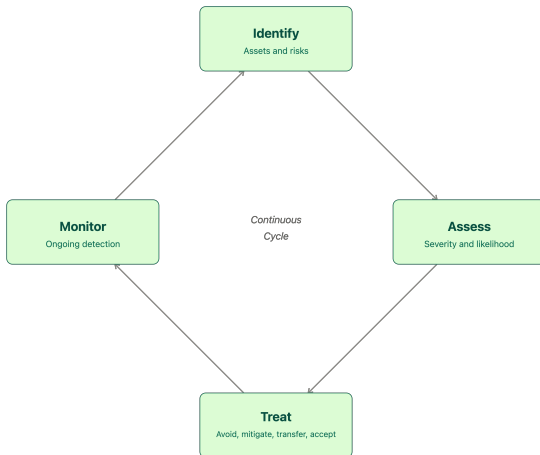
Risk, Threat, and Vulnerability

- **Threat** : Something that could cause harm, independent of whether it can actually succeed
- **Vulnerability** : A weakness that a threat could exploit
- **Risk** : The combination of a threat, a vulnerability it could exploit, and the value of what is at stake
- Risk is what is actually managed, threats and vulnerabilities alone often cannot be eliminated entirely

What is Risk Management?

- No organisation has unlimited resources to counter every possible threat
- Risk management is the discipline of deciding, systematically, what is worth protecting against and how much
- A continuous cycle, not a one-time exercise : identify, assess, treat, monitor, and repeat

What is Risk Management?



The Risk Formula

$$\text{Risk} = \text{Threat} \times \text{Vulnerability} \times \text{Asset Value}$$

- Risk is not severity alone, and not likelihood alone, it is the product of both
- A catastrophic but near impossible event and a trivial but near certain event can carry comparable risk

Major Categories of Information Security Risk

- **Technical** : Software vulnerabilities, misconfigurations, outdated systems
- **Operational** : Process failures, human error, inadequate procedures
- **Physical** : Theft, natural disaster, hardware failure
- **Third-party / vendor** : A supplier's failure becoming the organisation's problem
- **Compliance / legal** : Regulatory penalties, contractual liability
- **Reputational** : Loss of customer trust, even without direct financial loss

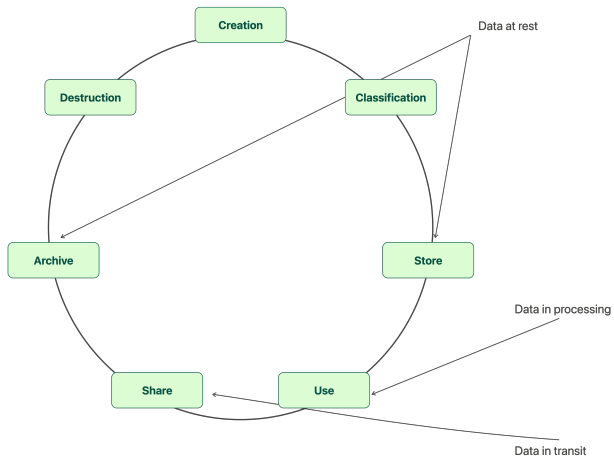
The Risk Management Process

- Asset Identification : What do we have that is worth protecting?
- Threat Identification : What could target each asset?
- Vulnerability Identification : Does an exploitable weakness actually exist?
- Risk Assessment : How likely, and how costly, if it happens?
- Feasibility Analysis : Is a response to this actually practical?

Asset Identification

- An inventory of everything of value including data, systems, hardware, and intangible assets such as reputation and intellectual property
- An **information asset** is a body of information, defined and managed as a single unit (e.g. PII, a database table of critical records)
- Every asset has recognisable and manageable value, risk, content, and lifecycle
- Risk cannot be assessed for an asset the organisation does not know it has

Information Lifecycle



Subjects, Objects, and Access

- Information assets are used by individuals or processes which are the **subjects**
- The asset being acted upon is the **object**
- Access typically takes the form of a read or a write



Threat Identification

- For each identified asset, systematically enumerate what could go wrong
- Pairs each asset with the threats that could plausibly target it
- This is where threat identification is actually applied

Vulnerability Identification

- For each threat identified ask “does an exploitable weakness actually exist?”
- A threat with no exploitable vulnerability is not yet a risk

Risk Assessment

$$R = P \times V - M + U$$

- **P** : Probability of the risk occurring
- **V** : Vulnerability, or value at stake
- **M** : Mitigating effect of controls already in place, subtracted
- **U** : Uncertainty in the estimate itself, added back, since poorly understood risks warrant extra caution

Feasibility Analysis

- Not every identified risk can be treated the same way
- Asks whether a proposed response is actually practical in means of budget, technical capability, time
- A theoretically ideal control that costs more than the asset it protects is not a feasible one

Threat Modeling

- Systematically asking “What could realistically go wrong here, and who or what would cause it?”
- Doing this rigorously, rather than by unstructured brainstorming, is called **threat modeling**

STRIDE

- **Spoofing** : Pretending to be someone or something else
- **Tampering** : Unauthorised modification of data
- **Repudiation** : Denying an action with no way to prove otherwise
- **Information disclosure** : Exposing data to those who should not see it
- **Denial of service** : Degrading or blocking legitimate access
- **Elevation of privilege** : Gaining more access than intended

DREAD

- **D**amage potential : How severe would this actually be
- **R**eproducibility : How easily can it be triggered repeatedly
- **E**xploitability : How much skill or effort does exploitation require
- **A**ffected users : How many users or systems would be impacted
- **D**iscoverability : How easily would an attacker find this in the first place
- Used to rank threats that STRIDE has already identified

PASTA

- **P**rocess for **A**ttack **S**imulation and **T**hreat **A**nalysis
- A seven-stage methodology, explicitly risk-centric and business-aligned
- Begins from business objectives, only later moving to technical attack simulation

OCTAVE

- **Operationally Critical Threat, Asset, and Vulnerability Evaluation**
- Organisation-driven rather than purely technical which may include approaches such as internal workshops, not necessarily led by security specialists
- Identifies critical assets and threats from an operational and business perspective first

Choosing a Methodology

Methodology	Best suited for	Character
STRIDE	Assessing a specific system or application	Lightweight, technical
DREAD	Ranking threats STRIDE has already found	Lightweight, technical
PASTA	Enterprise-wide, business aligned assessment	Heavyweight, formal
OCTAVE	Organisational self assessment	Heavyweight, workshop-driven

Vulnerability Assessment

- The hands on process of finding weaknesses that actually exist in current systems
- Techniques : Vulnerability scanners, penetration testing, code review, configuration audits

Threat Modeling vs Vulnerability Assessment

- Threat modeling asks “what could go wrong here, in principle?”
- Vulnerability assessment asks “what weaknesses actually exist right now?”
- The two feed each other, threat modeling directs where to focus assessment and findings refine the threat model

Summary

- **Risk** is the product of threat, vulnerability, and asset value, not any one of these alone
- The risk management process runs as a cycle, identify assets, identify risks, assess them, check feasibility
- **Threat modeling** (STRIDE, DREAD, PASTA, OCTAVE) systematically finds what could go wrong
- **Vulnerability assessment** finds what is actually wrong right now
- Together, these answer the question every risk decision depends on, “what should we actually worry about?”